



**UNIVERSIDAD TECNOLÓGICA
DE QUERÉTARO**

Alumna:

Vasquez Noyola Andrea

Grupo:

IDGS17

Matrícula:

2023148002

Materia:

Seguridad en el Desarrollo de Aplicaciones

Práctica 2 - Parte 2

En esta práctica se evaluaron los endpoints `/api/user/{id}` y `/api/users`. Al consumirlos, la API devuelve el objeto completo del usuario. Esto incluye información altamente sensible como el campo `Password` , lo cual representa un compromiso crítico de credenciales, además de que tampoco cuenta con seguridad al no tener las contraseñas hasheadas.

El endpoint `/api/user/{id}` es vulnerable a IDOR porque no verifica quién está realizando la solicitud. Cualquier usuario (incluso no autenticado) puede solicitar el ID de otra persona y el servidor entregará los datos sin comprobar si el solicitante es el dueño legítimo de esa información.

El uso de identificadores numéricos e incrementales (1, 2, 3...) agrava críticamente la vulnerabilidad. Dado que los IDs son predecibles, un atacante puede crear un script automatizado que itere secuencialmente sobre los números (ej. `GET /api/user/1`, `GET /api/user/2...`) para descargar masivamente toda la base de datos de usuarios en cuestión de segundos.

Tabla con campos sensibles expuestos

Recurso	Acceso observado	Riesgo
<code>/api/user/{id}</code>	<code>{"id":3,"username":user2,"email":user2@test.com,"balance":750.00,"password":password}</code>	Acceso a datos de terceros
<code>/api/users</code>	<code>[{"id":1,"username":"admin","password":"admin","email":"admin@test.com","balance":1000.00,"createdAt":"2024-01-01T00:00:00"}, {"id":2,"username":"user1","password":"123456","email":"user@test.com","balance":500.00,"createdAt":"2024-01-01T00:03:00"}, {"id":3,"username":"user2","password":"password","email":"user2@test.com","balance":750.00,"createdAt":"2024-01-01T00:00:00"}]</code>	Acceso a datos de terceros
Password	<code>"password":"123456,"</code>	Compromiso de credenciales